

# 法院立案/强执查询助手

## 管理员账号、设备与权限手册

版本：0.2.0

后台地址：<https://court.hyhbrand.xyz>

### 1. 首次登录

- 使用部署人员一次性提供的初始管理员账号登录。
- 立即在用户管理中重置管理员密码。
- 验证旧会话已撤销，再用新密码重新登录。
- 至少保留一个启用的 admin；系统会拒绝停用、删除或降级最后一个 admin。

### 2. 角色边界

| 能力             | admin | user |
|----------------|-------|------|
| 管理系统用户、角色和密码   | 是     | 否    |
| 创建、修改、停用平台账号   | 是     | 否    |
| 在后台按需查看平台凭据    | 是     | 是    |
| 上传模板、查询案件和查看截图 | 是     | 是    |
| 批准或撤销扩展设备      | 是     | 否    |
| 查看与下载报表        | 全部    | 仅本人  |

### 3. 系统用户管理

- 新建用户时使用个人账户，不共用管理员账号。
- 普通操作人员使用 user 角色；只有需要管理权限时才授予 admin。
- 人员离岗时先停用用户，再撤销其会话；需要保留历史关联时使用软删除。
- 重置密码后通过安全渠道单独通知本人，禁止在多人群发送。

### 4. 平台账号管理

- 使用不包含明文账号的内部标签，例如“华东组-A”。
- 录入平台账号和密码；后台使用 AES-256-GCM 加密保存。
- 密码变更时使用“替换凭据”，不要新建重复标签。
- 不再使用的账号先停用；删除为软删除，既有案件不会级联消失。
- 明文查看接口禁止缓存，查看后关闭页面并避免屏幕共享。

## 5. 扩展设备批准

1. 操作人员在 Setup 点击“请求后台授权”，口头或当面提供六码。
2. 在后台核对设备标签、六码和发起时间。
3. 仅批准已确认的客户电脑；不清楚来源时拒绝。
4. 批准后让操作人员刷新 Setup，验证状态为“已授权”。
5. 设备遗失、人员离岗或电脑重装时立即撤销或删除设备。

扩展令牌与设备绑定，有效期 30 天。Origin 不是身份凭据；只有管理员批准后的设备才能取得令牌。

## 6. 日常管理

- 每日查看待人工案件、失败任务和设备异常。
- 只清理已结束任务；清理不会删除案件、截图、导入批次、报表或平台账号。
- 监控报表与案件的 30 天保留结果，确认过期对象和元数据一致删除。
- 每月复核用户、平台账号和设备列表，停用不再需要的主体。

## 7. 安全事件处理

发现异常登录、设备丢失或凭据疑似泄漏时：

1. 撤销相关设备和用户会话。
2. 停用相关平台账号并在法院平台更换密码。
3. 通知运维检查服务器和 Nginx 脱敏日志；不要复制请求体或业务明文。
4. 更换后台用户密码；如怀疑主密钥泄漏，停止服务并按专项密钥迁移流程处理。
5. 记录事件时间、影响范围和处置结论，不记录真实密码或完整业务数据。